

Cyber Threat Intelligence

Executive Briefing

Report Date: June 28, 2026

Generated: 2026-06-28 19:11 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	7	8	1	16

2. Executive Summary

This Cyber Threat Intelligence briefing for June 28, 2026, details the assessment of 16 identified vulnerabilities, categorized as 0 Critical, 7 High, 8 Medium, and 1 Low severity. The current organizational risk posture is assessed as High, characterized by significant potential for unauthorized access and integrity compromise within our software supply chain infrastructure. CVE-2026-55698 represents the highest priority threat due to its potential for arbitrary package resolution, which could facilitate downstream supply chain attacks if left unmitigated. We have moved to an accelerated patching posture, requiring immediate remediation efforts for all identified High-severity vulnerabilities to neutralize the threat of environmental exploitation.

3. Critical Action List

- Execute immediate emergency patching of all internal build environments utilizing pnpm to address the CVE-2026-55698 package resolution exploit by EOD June 29, 2026.
- Implement strict file-system sandboxing on Gonic infrastructure to mitigate CVE-2026-49340 arbitrary file write risks within 48 hours.
- Update all native paquet configurations to resolve CVE-2026-55697 repository-controlled configuration vulnerabilities by July 1, 2026.
- Force an organizational reset of build manifest authentication protocols to remediate CVE-2026-55487 identity spoofing risks by July 1, 2026.
- Restrict path resolution permissions on all development and staging servers to block path traversal associated with CVE-2026-55700 by July 2, 2026.
- Conduct an automated compliance scan across all CI/CD pipelines to identify and isolate remaining legacy instances vulnerable to high-severity package manager flaws by July 2, 2026.
- Initiate a comprehensive integrity audit of the software supply chain build artifacts to ensure no unauthorized persistence mechanisms exist, with a report due by July 3, 2026.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	CVSS Score	Severity	Urgency	CWE
CVE-2026-55698	8.8	High	89/100	CWE-345
CVE-2026-49340	8.1	High	83/100	CWE-22
CVE-2026-55697	7.5	High	78/100	CWE-78
CVE-2026-55487	7.5	High	78/100	CWE-346
CVE-2026-55700	7.1	High	74/100	CWE-22
CVE-2026-49338	7.1	High	74/100	CWE-285
CVE-2026-49339	7.1	High	74/100	CWE-22
CVE-2026-53523	6.8	Medium	71/100	CWE-601
CVE-2026-55699	6.5	Medium	69/100	CWE-22
CVE-2026-55180	6.5	Medium	69/100	CWE-200
CVE-2026-53522	6.5	Medium	69/100	CWE-770
CVE-2026-53465	6.2	Medium	66/100	CWE-122
CVE-2026-54243	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	4.0	Medium	46/100	CWE-401
CVE-2026-54242	4.9	Medium	44/100	CWE-367
CVE-2026-54244	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1204, T1195

The pnpm project environment lockfile implementation fails to properly validate package resolution, allowing for short-circuiting of the resolution process. An attacker can supply malicious lockfile bytes that the manager executes, leading to unauthorized code execution during the installation phase.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1059, T1068

Gonic is susceptible to an arbitrary file write vulnerability during playlist creation, where authenticated users can inject M3U content to arbitrary paths on the host. This could be leveraged for system-wide configuration changes or remote code execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-55697

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1203, T1059

A vulnerability in pnpm allows a repository-controlled configuration to influence the selection of a paquet native installation engine. This flaw allows an attacker to execute arbitrary commands on the system running the build process.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1195, T1059

The pnpm package manager suffers from a manifest identity spoofing vulnerability, allowing an attacker to bypass build restrictions and trigger arbitrary lifecycle scripts. This flaw can lead to full system compromise during package installation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1190

The pnpm package manager is vulnerable to path traversal during the stage download process due to improper validation of manifest names and versions. An attacker can exploit this to write files outside of the intended destination directory, potentially leading to arbitrary code execution or system compromise.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1592, T1078

The Subsonic API exhibits an insecure direct object reference (IDOR) vulnerability that permits authenticated users to read or delete playlists belonging to other users. This compromise of access controls impacts user data confidentiality and integrity.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1190

Gonic contains a path traversal vulnerability in its playlist ID parameter that bypasses ownership checks. An attacker can leverage this flaw to access or delete playlists belonging to other users, resulting in unauthorized data manipulation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-53523

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601

MITRE ATT&CK: T1566

Nezha Monitoring is vulnerable to host header injection during the OAuth2 redirect process. An attacker can leverage this to redirect users to arbitrary external domains, facilitating phishing campaigns.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55699

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485, T1070

A vulnerability in pnpm allows for the deletion of the PNPM_HOME directory during a global package removal process when a reserved bin name is utilized. This can result in a denial of service by removing critical configuration files or environment state data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-55180

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-200

MITRE ATT&CK: T1048, T1552

Pnpm is vulnerable to a configuration flaw where environment secrets can be inadvertently expanded into registry requests. This facilitates the unauthorized exfiltration of sensitive credentials to third-party domains.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-53522

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

Nezha Monitoring contains an issue with unbounded WebSocket streams, leading to resource exhaustion. This can be exploited by an unauthenticated attacker to cause a denial of service on the monitoring instance.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-53465

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122

MITRE ATT&CK: T1203, T1195

ImageMagick contains a heap-based buffer overflow in the SF3 encoder that occurs during the processing of multi-frame images. An attacker may trigger this vulnerability via a maliciously crafted file, potentially leading to application crashes or arbitrary code execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-54243

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1204

Statamic is vulnerable to CSV formula injection when exporting form submission data. An attacker can inject malicious spreadsheet formulas that are executed when an administrator opens the exported file.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-53464

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401

MITRE ATT&CK: T1499

A memory leak vulnerability exists in the ImageMagick wand option parser, which can be triggered when providing specially crafted invalid arguments. Repeated exploitation of this defect could lead to significant memory exhaustion and denial of service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54242

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1046, T1190

Statamic is susceptible to server-side request forgery (SSRF) via the Glide image processing component using DNS rebinding. This allows an attacker to probe internal network services otherwise unreachable from the public internet.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-54244

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1078

Statamic CMS has an authorization flaw where users with view-only permissions can submit content for Live Preview, an action restricted to editors. While limited, this impacts the integrity of content management workflows.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>